
Barford Primary School Audit Report**Audit Date: 29/10/19****Report: Year 2 visit 1****DPE: Stuart Lee****School member: Lynne Brown**

1. Visit details

Key GDPR documentation was reviewed and DPE best practice areas, compliance checklists, SLAs, record of processing and compliance manager were discussed/demonstrated with the school. The school had previously had a remote session with Kalina (DPE). The Summer 2019 NCC GDPR themed audit was also discussed and talked through (refer to section 7).

2. Audit walk findings

No audit walk was completed. We discussed the security of the front office. Lynne has in-trays that are locked away at night. Suggested these should be secured when not in the office for any length of time i.e. going home for lunch. School has contract cleaners (NORSE). The school had considered key code entry but as the medical cabinet is positioned within, have decided not to at present.

Action points: Add information at reception to inform visitors where they can access the school's privacy statement from i.e. school website (not discussed during visit);

Introduce the best practice guide that can be displayed and used to support raising staff awareness:
<https://kb.dataprotection.education/best-practice-library/documents/drip-feeds/57-dpe-quick-reference-guide>

3. Compliance actions that should now be completed

Initial documents:

- **Privacy Notice**
- **GDPR Policy**
- **Data Breach Procedure**
- **SAR procedure**
- **Photo and Video consent, guidelines and records**

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. If using GDPRiS this should also be kept updated. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

3.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist

- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

3.2. Staff training

GDPR training should be completed and documented. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

3.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

3.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

4. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

5. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommend schools develop procedures to ensure iPads/Tablets can be accounted for daily and data (i.e photos) can be cleared if lost or stolen (for Apple devices: [Erase your device](#))

6. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

6.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

7. Norfolk County Council Summer GDPR audits

NCC auditors completed a number of themed GDPR audits during the summer term 2019. DPE has provided feedback to the findings which can be obtained from the News section of the school website: <https://kb.dataprotection.education/news-top/news>